

Annual Security Audit Report 2025

IT Security Assessment & Penetration Testing Results | December 2025

1. Audit Scope and Methodology

This report presents the findings of the annual information security audit conducted between October 15 and December 20, 2025, covering TechViet Solutions' entire technology infrastructure, application portfolio, and security operations. The audit was performed by the internal IT Security team under the direction of Le Hoang Nam (CISO), with external validation provided by KPMG Vietnam's cybersecurity practice. The audit methodology follows ISO 27001:2022 Annex A controls, supplemented by OWASP ASVS 4.0 for application security testing and CIS Benchmarks v8 for infrastructure hardening assessment. The audit scope encompasses: all production and staging environments (24 application servers, 6 database servers, 4 GPU servers, and associated network infrastructure), all customer-facing applications (ChatAssist platform, Customer Portal, Partner API Gateway), internal applications (HR Portal, Finance System, Project Management Tool), third-party SaaS integrations (Okta, Datadog, Slack, GitHub, AWS, Google Workspace), and security operations processes (incident response, vulnerability management, access management, security awareness training). Testing activities included: automated vulnerability scanning using Nessus Professional and Qualys WAS, manual penetration testing of the ChatAssist platform and Partner API Gateway, source code security review of 12 critical repositories using Semgrep and CodeQL, configuration audit of all network devices and firewalls, review of IAM policies and access logs across all systems, social engineering assessment (phishing simulation sent to all 350 employees), physical security assessment of the data center and office premises, and review of all security-related policies, procedures, and training records.

2. Executive Summary of Findings

The 2025 security audit identified a total of 156 findings across all domains, classified as follows: Critical (immediate action required): 4 findings, High (remediation within 30 days): 18 findings, Medium (remediation within 90 days): 47 findings, Low (remediation within 180 days): 52 findings, Informational (best practice recommendations): 35 findings. This represents an improvement from the 2024 audit, which identified 6 Critical and 23 High findings. The overall security maturity score, measured against the NIST Cybersecurity Framework, increased from 3.2/5.0 in 2024 to 3.6/5.0 in 2025, reflecting the significant investment in security tooling and processes made during the year. However, the four Critical findings require immediate attention as they represent active or imminent threats to the confidentiality, integrity, or availability of TechViet's systems and data.

3. Critical Findings

3.1 CRIT-001: SQL Injection in Legacy Admin Panel

During the manual penetration test of the legacy PHP admin panel (admin.internal.techviet.vn), the testing team discovered a SQL injection vulnerability in the user search functionality. The vulnerable endpoint is GET /api/users/search?q=[input], which directly concatenates user input into a SQL query without

parameterization or input validation. The tester demonstrated that this vulnerability allows: extraction of the entire user database including hashed passwords (the password hashing uses bcrypt with a cost factor of 12, which provides reasonable protection against offline cracking), extraction of the admin_sessions table which contains active session tokens that could be used for session hijacking, execution of arbitrary SQL commands including UPDATE and DELETE statements (the database user has full DML privileges), and potential for operating system command execution through PostgreSQL's COPY TO PROGRAM functionality (though this was not tested due to scope limitations). This vulnerability is rated Critical because: the admin panel has access to sensitive employee data including salary information, performance reviews, and personal identification numbers; the panel is accessible from the corporate network without VPN (any employee on the office Wi-Fi can reach it); and the lack of Web Application Firewall (WAF) or SQL injection detection means that exploitation would not be detected by current monitoring. Recommended remediation: immediate (within 24 hours) deployment of a WAF rule to block SQL injection patterns on this endpoint; short-term (within 7 days) patching of the vulnerable code to use parameterized queries; medium-term (within 30 days) complete retirement of the legacy admin panel as planned in the application rationalization roadmap, replacing it with the new React-based admin dashboard that was deployed to staging in November 2025. The CISO has issued a security directive requiring the WAF rule to be deployed by end of business on the day this report is delivered.

3.2 CRIT-002: Exposed AWS Access Keys in GitHub Repository

The automated secret scanning component of the code review identified AWS access keys committed to the techviet/data-pipeline repository on November 3, 2025, in commit hash a3f7c2d. The keys belong to the IAM user 'data-pipeline-prod' and have the following permissions: full access to S3 buckets (including the customer data bucket s3://techviet-prod-customer-data), read/write access to DynamoDB tables used by the data pipeline, and permission to invoke Lambda functions in the production account. Although the repository is private (accessible only to TechViet GitHub organization members), this still represents a Critical risk because: any of the 180 developers with GitHub access could use these keys to access production customer data, the keys have been present in the git history for 47 days before detection, and if any developer's GitHub account were compromised, the attacker would gain access to production data through these keys. Investigation by the Security team confirmed that the keys were committed by a junior developer who hardcoded them in a configuration file while debugging a data pipeline issue. The developer's team lead was unaware of the commit because the repository does not require code review for the 'config/' directory (an exception that was added 18 months ago and never reviewed). Remediation actions: the exposed keys were immediately rotated upon discovery (December 2, 2025), and CloudTrail logs were reviewed for any unauthorized usage during the 47-day exposure window (no suspicious activity was found). Additional measures include: enabling GitHub Advanced Security secret scanning with push protection on all repositories, implementing pre-commit hooks using gitleaks to prevent secrets from being committed locally, removing the code review exception for the config/ directory, and conducting a full scan of all 87 repositories for additional exposed secrets (this scan found 3 additional Low-severity instances of API keys for non-production services).

3.3 CRIT-003: Unpatched Critical CVE on Production Database Server

The Nessus vulnerability scan identified that the production PostgreSQL database server (db-prod-01) is running PostgreSQL 15.4, which is affected by CVE-2025-1094 (CVSS 9.1), a critical vulnerability that allows authenticated users to execute arbitrary code on the database server through a specially crafted SQL query. PostgreSQL released the patch (version 15.8) on September 15, 2025, meaning the server has been unpatched for over 3 months. The vulnerability is rated Critical because: the database server hosts production customer data, the CVE allows remote code execution from any authenticated database connection, and several application services connect to the database using shared credentials with elevated privileges. The root cause investigation revealed that the database team's patch management

process relies on manual quarterly patch cycles, and the Q4 2025 patch cycle was deferred because the database administrator was assigned to the cloud migration project and the patch window conflicted with the Q4 sales event freeze period. There is no automated alerting for critical CVEs affecting production database versions. Remediation: schedule an emergency maintenance window to upgrade PostgreSQL to version 15.8, which includes fixes for CVE-2025-1094 and 7 other security-related bugs. Implement automated CVE monitoring for all production software versions using the Datadog CVE tracking integration. Revise the patch management policy to require critical CVEs (CVSS $\geq$ 9.0) to be patched within 7 days regardless of freeze periods.

3.4 CRIT-004: Insufficient Network Segmentation for PCI DSS Compliance

The network architecture review found that the payment processing components (which handle credit card data for ChatAssist Premium subscriptions) are not adequately segmented from the general corporate network. Specifically: the payment processing service runs on the same application servers as other ChatAssist microservices, sharing the same VLAN and security group; the database tables containing tokenized card data are in the same PostgreSQL cluster as other application data (different schema, but same server and same backup system); and developers with SSH access to the application servers can potentially access the payment processing service's environment variables, which include the payment gateway API key. This configuration violates PCI DSS Requirement 1 (Install and maintain a firewall configuration to protect cardholder data) and Requirement 2 (Do not use vendor-supplied defaults for system passwords and other security parameters). While TechViet is not currently required to be PCI DSS certified (we use Stripe as our payment processor, which handles the actual card data), our agreement with Stripe requires that we maintain reasonable security controls around the payment integration. More importantly, the lack of segmentation means that a compromise of any ChatAssist microservice could potentially pivot to the payment processing service and access the Stripe API key, which could be used to issue unauthorized refunds or access customer payment information through the Stripe API. Remediation: migrate the payment processing service to a dedicated, isolated VLAN with its own firewall rules allowing only HTTPS traffic from the ChatAssist API Gateway; move the payment-related database tables to a separate PostgreSQL instance with restricted access; rotate the Stripe API key and store it in AWS Secrets Manager (or HashiCorp Vault on-premises) instead of environment variables; implement network monitoring rules to detect any unauthorized traffic to/from the payment processing VLAN.

4. High-Severity Findings Summary

The 18 High-severity findings span multiple domains and represent significant gaps that, while not immediately exploitable or as impactful as the Critical findings, require remediation within 30 days to maintain an acceptable risk posture. The findings are grouped by domain below with specific remediation timelines. Application Security (6 findings): HIGH-001 through HIGH-006 cover issues discovered during the penetration test and code review. HIGH-001 identifies a Cross-Site Scripting (XSS) vulnerability in the ChatAssist web client's message rendering component, where user-submitted messages containing HTML are rendered without sanitization in the admin dashboard view. HIGH-002 identifies an Insecure Direct Object Reference (IDOR) in the Customer Portal's document download endpoint, where changing the `document_id` parameter allows access to other customers' uploaded documents. HIGH-003 identifies missing rate limiting on the Partner API authentication endpoint, which could be exploited for credential stuffing attacks. HIGH-004 identifies the use of an outdated JWT library (jsonwebtoken v8.5.1) with a known signature bypass vulnerability. HIGH-005 identifies insufficient input validation in the ChatAssist file upload feature, allowing upload of executable files that could be used in social engineering attacks against support agents. HIGH-006 identifies a Server-Side Request Forgery (SSRF) vulnerability in the reporting service's PDF generation feature, where the URL parameter for including external images is not validated. Infrastructure Security (5 findings): HIGH-007 through HIGH-011 address infrastructure hardening gaps. HIGH-007 identifies 12 servers running outdated operating system versions (Ubuntu 20.04 LTS, which will

reach end of standard support in April 2025). HIGH-008 identifies that TLS 1.0 and 1.1 are still enabled on the F5 load balancer for backward compatibility with legacy API clients, despite being deprecated. HIGH-009 identifies that backup encryption keys are stored on the same server as the backups, violating the principle of key separation. HIGH-010 identifies that the Palo Alto firewall firmware is two major versions behind the current release. HIGH-011 identifies that SNMP v2c (with community string 'techviet') is enabled on network switches, which transmits credentials in plaintext. Identity and Access Management (4 findings): HIGH-012 through HIGH-015 address access control issues. HIGH-012 identifies 14 inactive user accounts (employees who left more than 30 days ago) that have not been deprovisioned. HIGH-013 identifies that 8 service accounts use shared credentials that have not been rotated in over 12 months. HIGH-014 identifies that the root account of the AWS Management Account does not have MFA enabled. HIGH-015 identifies that emergency break-glass procedures for privileged access are not documented or tested. Security Operations (3 findings): HIGH-016 through HIGH-018 address gaps in detection and response capabilities. HIGH-016 identifies that security log retention is only 30 days for application logs, which is insufficient for forensic investigation of advanced persistent threats. HIGH-017 identifies that the SIEM (Datadog Security Monitoring) has 23 disabled detection rules, including rules for lateral movement and privilege escalation. HIGH-018 identifies that the incident response plan has not been tested through a tabletop exercise in 2025.

5. Phishing Simulation Results

The annual phishing simulation was conducted on November 15, 2025, targeting all 350 employees with three different phishing scenarios of varying sophistication. Scenario 1 (Low sophistication): a generic 'Your password is expiring' email purporting to be from IT Support, sent from an external domain (techviet-it.com) with obvious grammatical errors. Result: 12% click rate (42 employees clicked the link), 4% credential submission rate (14 employees entered their credentials on the fake login page). Scenario 2 (Medium sophistication): a targeted email appearing to be from the HR department announcing mandatory benefits enrollment, using the correct HR department naming convention and sent from a lookalike domain (techviet-hr.vn). Result: 28% click rate (98 employees), 15% credential submission rate (53 employees). Scenario 3 (High sophistication): a spear-phishing email targeting the Engineering department, appearing to be a GitHub notification about a critical security vulnerability in one of their repositories, using a lookalike domain (github-techviet.com) and including the recipient's actual repository names (obtained from public GitHub activity). Result: 41% click rate (74 out of 180 engineers), 22% credential submission rate (40 engineers). These results show improvement from the 2024 simulation (which had a 35% average click rate vs. 27% this year), but the high click rate for the sophisticated engineering-targeted scenario is concerning, especially given that engineers have privileged access to production systems. Of particular concern: 6 employees who submitted credentials in the simulation also have production SSH access, meaning a real attack could have led to a production compromise. Three of these employees are in the DevOps team with root access to production servers. The Security Awareness team has developed a targeted remediation program for high-risk employees, including mandatory one-on-one coaching sessions, additional phishing awareness training, and enrollment in the advanced threat recognition course. Additionally, the CISO has mandated that all employees with production access must use hardware security keys (YubiKey) for authentication by January 31, 2026, eliminating the risk of credential theft through phishing.